

INFORME DE PRUEBAS DE SEGURIDAD WEB

Grupo evaluador:	Grupo #9
Grupo evaluado:	Grupo #2

#	Categoría	Prueba / objetivo	Dato de prueba	Pasos de ejecución	Resultado esperado seguro
1	XSS	Probar si un campo de texto ejecuta JavaScript reflejado.	<script>alert('XSS')</script>	Ingresar el dato en un campo visible como búsqueda, usuario, nombre o comentario. Enviar el formulario.	La aplicación debe mostrar el texto escapado o rechazarlo. No debe aparecer alerta ni ejecutarse código.
2	XSS	Validar si el sistema bloquea eventos HTML peligrosos.		Ingresar el dato en un campo de descripción, mensaje o comentario. Guardar o enviar.	El contenido debe sanitizarse. No debe ejecutarse el evento onerror.
3	XSS	Probar inyección en atributos HTML.	"><svg onload=alert('XSS')>	Ingresar el dato en campos como nombre, apellido, dirección o asunto. Revisar cómo se renderiza.	La aplicación debe neutralizar comillas, etiquetas y eventos. No debe modificar la estructura HTML.
4	XSS	Probar XSS almacenado en datos que luego se vuelven a mostrar.	Prueba segura <script>alert('XSS')</script>	Guardar el dato en una pantalla que luego se consulte otra vez, por ejemplo perfil, comentario o registro.	Al volver a visualizar el registro, el texto no debe ejecutarse. Debe verse escapado o filtrado.
5	XSS	Probar XSS por parámetro en la URL.	?buscar=<script>alert('XSS')</script>	Colocar el parámetro en una URL de búsqueda o filtro. Cargar la página.	La página no debe ejecutar scripts desde la URL. Debe validar o codificar el parámetro.
6	SQLi	Verificar posible bypass de login por inyección en usuario.	' OR '1'='1' --	Escribir el dato en el campo usuario y cualquier texto en contraseña. Intentar iniciar sesión.	No debe iniciar sesión. El mensaje debe ser genérico: usuario o contraseña incorrectos.
7	SQLi	Verificar posible bypass de login por inyección en contraseña.	' OR '1'='1' --	Escribir un usuario existente o de prueba y colocar el dato en contraseña. Intentar entrar.	No debe autenticar. La consulta debe estar parametrizada y no concatenada.
8	SQLi	Probar inyección en filtros o búsquedas.	%' OR '1'='1	Ingresar el dato en un buscador, filtro de tabla o campo de consulta. Ejecutar búsqueda.	No debe listar registros indebidos ni mostrar toda la base. Debe validar la entrada.
9	SQLi	Probar manejo seguro de caracteres especiales.	'; -- "	Ingresar esos caracteres en campos de texto y enviar. Observar si aparecen errores técnicos.	No debe mostrar errores SQL, rutas del servidor, stack trace ni detalles de base de datos.
10	SQLi	Probar inyección en parámetro numérico.	?id=1 OR 1=1	En una pantalla con parámetro id, modificar el valor en la URL o campo oculto y recargar.	Debe aceptar solo números válidos y autorizados. No debe devolver registros extra.
11	IDOR	Verificar acceso indebido cambiando un ID en la URL.	/perfil?id=101 → /perfil?id=102	Entrar con un usuario de prueba. Cambiar el id por otro número y cargar.	Debe negar acceso o mostrar solo datos del usuario autenticado.
12	IDOR	Verificar edición indebida cambiando un campo oculto.	idUsuario=101 → idUsuario=102	Con DevTools, revisar el formulario, cambiar el id oculto y enviar cambios.	El servidor debe ignorar IDs manipulados o validar permisos antes de guardar.
13	IDOR	Verificar descarga de archivos o recursos por ID predecible.	/descargar?archivoid=5 → archivoid=6	Abrir un recurso propio y cambiar el número del ID. Intentar descargar o ver otro recurso.	Debe bloquear recursos que no pertenecen al usuario o rol autorizado.
14	IDOR	Verificar eliminación o modificación de registros ajenos.	/editar?id=10 o /eliminar?id=10	Intentar acceder a editar/eliminar un registro cambiando el id por uno no propio.	Debe responder 403, redirigir o negar la acción. No debe modificar datos ajenos.
15	Fuerza bruta	Verificar control ante varios intentos incorrectos de código o contraseña.	Ingresar código/contraseña incorrecta 5 veces seguidas	Intentar manualmente el mismo usuario con códigos o contraseñas incorrectas varias veces.	Debe aplicar límite de intentos, bloqueo temporal, captcha o registro de intentos. El mensaje no debe revelar si el usuario existe.
16	Validaciones de campos	Verificar los campos vacíos en los inicios de sesiones	Ingresar y validar las fechas, si podría ingresar fecha futura en el campo de fecha	Intentar y probar si se puede poner fechas super viejas o muy futuras	Debe bloquear fechas futuras y debe dar error al poner una fecha muy vieja